

第10章

网络加密与密钥管理

网络加密是保护网络信息安全的重要手段。网络环境下的密钥管理是一项复杂而重要的技术。本章首先介绍有关网络加密的方式和硬件加密、软件加密的有关问题及实现。第8章曾讨论了密钥建立协议,本章将介绍密钥建立的通信模型,密钥分类、生成、长度与安全性、传递、注入、分配、证实、保护、存储、备份、恢复、泄漏、过期、吊销、销毁、控制、托管以及密钥管理自动化等有关内容。

10.1 网络加密的方式及实现

网络数据加密是解决通信网中信息安全的有效方法。虽然由于成本、技术和管理上的复杂性,网络数据加密技术目前还未在网中广泛应用,但从今后的发展来看,这是一个可取的途径。有关密码算法在密码学课程中已经全面介绍,这里主要讨论网络加密的方式。网络加密一般可以在通信的3个层次上来实现,相应的加密方式有链路加密、节点加密和端到端加密。下面分别对其加以讨论。

10.1.1 链路加密

链路加密对网络中两个相邻节点之间传输的数据进行加密保护,如图10-1所示。在受保护数据所选定的路由上,任意一对节点和相应的调制解调器之间都安装有相同的密码机,并配置相应的密钥,不同节点对之间的密码机和密钥不一定相同。

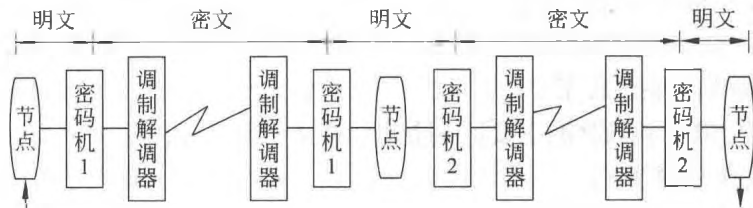


图 10-1 链路加密

对于在两个网络节点间的某一次通信链路,链路加密能为网上传输的数据提供安全保证。对于链路加密(又称在线加密)来说,所有消息都在传输之前被加密。每个节点首先对接收到的消息进行解密,然后再使用下一个链路的密钥对消息进行加密,并进行传输。在到达目的地之前,一条消息可能要经过许多通信链路的传输。

尽管链路加密在计算机网络环境中使用得相当普遍,但它并非没有问题。链路加密通常用在点对点的同步或异步线路上,它要求先对在链路两端的加密设备进行同步,然

后使用一种链模式对链路上传输的数据进行加密。这就给网络的性能和可管理性带来了副作用。

在线路和信号经常不通的海外或卫星网络中，链路上的加密设备需要频繁地进行同步，带来的后果是数据丢失或重传。另一方面，即使仅一小部分数据需要进行加密，也会使得所有传输数据被加密。

链路加密仅在通信链路上提供安全性，在一个网络节点，消息以明文形式存在。因此，所有节点在物理上必须是安全的，否则就会泄漏明文内容。然而，要保证每个节点的安全性需要较高的费用。

此外，在对称（单钥）加密算法中，用于解密消息的密钥与用于加密的密钥是相同的，该密钥必须秘密保存并定期更换。这样，在链路加密系统中，密钥分配就成了一个问题，因为每个节点必须存储与其相连接的所有链路的加密密钥，这就需要对密钥进行物理传送或者建立专用网络设施。网络节点地理分布的广阔性使得这一过程变得复杂，同时增加了密钥分配的费用。

10.1.2 节点加密

尽管节点加密能给网络数据提供较高的安全性，但它在操作方式上与链路加密是类似的：两者均在通信链路上为传输的消息提供安全性；都在中间节点先对消息进行解密，然后进行加密。因为要对所有传输的数据进行加密，所以加密过程对用户是透明的。

然而它与链路加密不同：节点加密不允许消息在网络节点以明文形式存在。它先把收到的消息进行解密，然后采用另一个不同的密钥进行加密。这一过程在节点上的一个安全模块中进行。

节点加密要求报头和路由信息以明文形式传输，以便中间节点能得到如何处理消息的信息。因此这种方法对于防止攻击者分析通信业务是脆弱的。

10.1.3 端到端加密

如图 10-2 所示，端到端加密是对一对用户之间的数据连续地提供保护。它要求各对用户（而不是各对节点）采用相同的密码算法和密钥。对于传送通路上的各中间节点，数据是保密的。



图 10-2 端到端加密

链路加密虽然能防止搭线窃听，但不能防止在消息交换过程中由于错误路由所造成的泄密，如图 10-3 所示。在链路加密方式下，由网络提供密码功能，故对用户来说是透明的。在端到端加密方式下，如果加密功能由网络自动提供，则对用户来说也是透明的；

如果加密功能由用户自己选定，则对用户来说就不是透明的。采用端到端加密方式时，只在需用加密保护数据的用户之间备有密码设备，因而可以大大减少整个网中使用密码设备的数量。

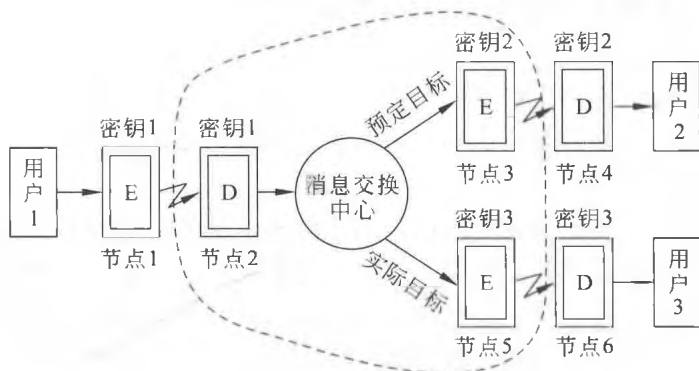


图 10-3 链路加密的弱点

端到端加密允许数据在从源点到终点的传输过程中始终以密文形式存在。采用端到端加密（又称脱线加密或包加密），消息在被传输时到达终点之前不进行解密。由于消息在整个传输过程中均受到保护，所以即使有节点被损坏也不会使消息泄漏。

端到端加密系统的开销小一些，并且与链路加密和节点加密相比更可靠，更容易设计、实现和维护。端到端加密还避免了其他加密系统所固有的同步问题。因为每个报文包均是独立被加密的，所以一个报文包所发生的传输错误不会影响后续的报文包。此外，从用户对安全需求的直觉上讲，端到端加密更自然些。单个用户可能会选用这种加密方法，以便不影响网络上的其他用户。此方法只需要源和目的节点是保密的即可。

端到端加密系统通常不允许对消息的目的地址进行加密，这是因为每个消息所经过的节点都要用此地址来确定如何传输消息。由于这种加密方法不能掩盖被传输消息的源点与终点，因此它对于防止攻击者分析通信业务是脆弱的。

10.1.4 混合加密

采用端到端加密方式只能对报文加密，报头则以明文形式传送，容易受业务流量分析攻击。为了保护报头中的敏感信息，可以用图 10-4 所示的端到端和链路混合加密方式。在此方式下，报文将被两次加密，报头则只由链路方式进行加密。

在明文和密文混传的网络中，可在报头的某个特定位上指示报文是否被加密，也可按线路协议由专用控制信息实现自动起止加密操作。

从成本、灵活性和安全性来看，一般端到端加密方式较有吸引力。对某些远程处理机构，链路加密可能更为合适。如当链路中节点数很少时，链路加密操作对现有程序是透明的，无须操作员干预。目前大多数链路加密设备是以线路的工作速度进行工作的，因而不会引起传输性能的显著下降。另外，有些远端设备的设计或管理方法不支持端到端加密方式。端到端加密的目的是对从数据的源节点到目的节点的整个通路上所传的数据进行保护。网络中所选用的数据加密设备要与数据终端设备及数据电路端接设备的接

口一致，并且要遵守国家和国际标准规定。

当前，信息技术及其应用的发展领先于安全技术，因此应大力发展安全技术以适应信息技术发展的需要。安全技术和它所带来的巨大效益远未被人们所认识，但对这个问题的认识绝不能太迟钝。信息的安全设计是个较复杂的问题，应当统筹考虑，协调各种要求，并力求降低成本。

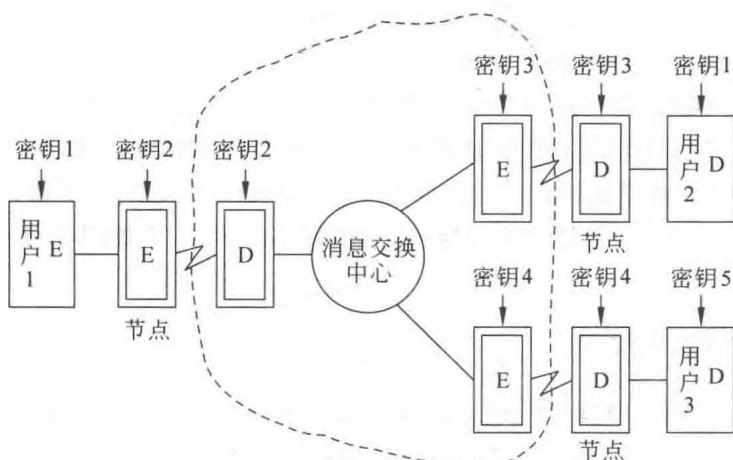


图 10-4 混合加密方式

10.2 硬件、软件加密及有关问题

10.2.1 硬件加密的优点

(1) 加密速度快。长期以来一直采用硬件实现加解密，主要原因是其加密速度快。许多算法，例如 DES 和 RSA，大都是位串操作，而不是计算机中的标准操作，它们在微处理器上的效率很低，故采用专用加密硬件实现在速度上具有优势。虽然有些算法在设计时考虑到用软件来实现，但算法安全性总是第一位的。另外，加密是一种强化的精细计算任务，改变一种微处理器芯片就可能使加解密的速度显著提高。

(2) 硬件安全性好。软件实现不可能有物理保护，攻击者可能有各种调试软件工具，可毫无觉察地偷偷修改算法。硬件可以封装，可以防篡改，因而难以入侵修改。ASIC 外面可以加上化学防护罩，任何试图解剖芯片的行动都会破坏其内部逻辑，导致存储的数据自行擦除。例如，美国的 Clipper 和 Capstone 芯片均有防篡改设计，且可以设计得使外部攻击者无法读出内部密钥。IBM 的密钥管理系统中的硬件模块也有防篡改设计。

硬件实现可进行电磁屏蔽设计，即 TEMPEST 设计，这样可防止电磁辐射泄漏 (Electronic Radiation)。当然必须选用可信赖厂家的产品。

(3) 硬件易于安装。多数硬件的应用独立于主机。如对于电话、FAX、数据线路等，在相应终端加入一个专用加密硬件，要比用微处理器实现加密更方便（但是多媒体的出现使这一情况发生了改变）；在计算机环境下，采用硬件也优于软件（如 PCMCIA 卡），

并能使加密透明且方便用户。若以软件实现需在操作系统的深层安装，这不容易实现；在计算机和 Modem 之间插入硬件，这对于计算机新手并非难事。

10.2.2 硬件种类

(1) 自配套加密模块（含有口令证实、密钥管理等）。

(2) 通信用加密盒。例如，T-1 加密盒特别适用于 FAX，多采用异步传输模式，也有用同步传送模式的。发展趋势是高速率和适应多种应用。

(3) PC 插件板。用于加密写入硬盘的所有数据，可以有选择地对送给软盘和出口的数据加密。由于无防辐射和防物理窜扰设计，故需要采取保护措施，使计算机不受影响。由于 PC 插件板种类繁多，且有些兼容性不是太好，在选购时要充分考虑硬件类型、操作系统、应用软件、网络特点等。与加密盒等产品一样，PC 插件板都有相应的安全密钥管理。

10.2.3 软件加密

任何加密算法都可用软件实现。软件实现的缺点是速度慢，占用一些计算和存储资源，且易被移植。软件实现的优点是灵活、轻便、可安装于多种机器上，且可将几个软件组合成一个系统，如与通信程序、字处理程序等相结合。

在所有主要的操作系统上都有加密软件可利用，如 Macintosh System 7，Windows NT，UNIX，Netscape 等。加密软件可用于加密单个文件。采用加密软件时密钥管理的安全性极为重要。不要在硬盘上存放密钥，加密后须将密钥和原来未加密的文件删除，这一重要措施常常被忽视。

软件加密实现的最大问题还是安全性。如在多任务环境下，文件进入系统后是否及时被加密？存于系统中的未加密密钥，可能是几分钟，也可能是几个月或更长，当攻击者出现时，文件可能还是明文状态；密钥也可能仍以明文形式存在硬盘某处，而被其用细齿梳（Fine Tooth Comb）检出。可以将加密操作设置为高优先级来降低这种风险，但即便如此仍有风险。

10.2.4 存储数据加密的特点

存储数据的加密与通信情况加密有很大不同，如破译其加密算法所需的密码分析时间仅由数据的价值限定；数据可能在另外的盘上、另一个计算机上或在纸上以明文形式出现；密码分析者有更多的机会实施已知明文破译；在数据库应用中，一串数据可能小于加密分组长度，而造成密文大于明文（数据扩展）；输入输出速度要求实现快速加解密（因而可能用硬件加密器件来实现）；密钥管理更为复杂，因为不同的人要访问不同的文件，或同一文件的不同部分等。

加密后文件的检索。对未设置记录项和文件结构的文本文件，加密后易于检索和解密恢复其明文；但对加密的数据库文件则难以检索，要将整个库文件解密后才能访问一个记录，很不方便。采用各记录独立地进行加密时，对分组重放（Block Replay）一类攻

击又较敏感。

10.2.5 文件删除

计算机上删除文件，常常是删去了文件名的第 1 个字母而使其不能检索，但文件本身仍存在原处，直到新的数据存入将其覆盖为止，在此之前用文件恢复软件就可以检出。因此，真正从存储器中消除所存储的内容需用物理上的重复写入方法。美国 NCSC (National Computer Security Center) 建议，要以一定格式的随机数重写至少 3 次。如第 1 次随机数为 00110101...；第 2 次随机数为 11001010...，是对第 1 次随机数取补；第 3 次随机数为 10010111...。原数据机密级越高，重写次数则应越多。很多商用软件采用 3 次重写，第 1 次用全 1，第 2 次用全 0，第 3 次用 1 和 0 相间数字。Schneier 建议为 7 次，第 1 次用全 1，第 2 次用全 0，后 5 次用安全的随机数。即使如此，NCSC 用电子隧道显微镜观测，仍然不能完全擦掉原数据。

更成问题的是计算机中广泛使用虚拟存储，它可以在任何时候进行读、写；即使不存储数据，当敏感文件上机操作后，也无从知道它是否已从硬盘中移出。偶尔将硬盘中所有未用的空间进行冲写 (overwrite)，并将文件与文件后面未用块组部分进行交换是有意义的。

10.3

密钥管理基本概念

一个系统中各实体之间通过共享的一些公用数据来实现密码技术，这些数据可能包括公开的或秘密的密钥、初始化数据及一些附加的非秘密参数。系统用户首先要进行初始化工作。

密钥是加密算法中的可变部分。对于采用密码技术保护的现代信息系统，其安全性取决于对密钥的保护，而不是对算法或硬件本身的保护。密码体制可以公开，密码设备可能丢失，同一型号的密码机仍可继续使用。然而一旦密钥丢失或出错，不但合法用户不能提取信息，而且可能使非法用户窃取信息。因此，产生密钥算法的强度、密钥长度及密钥的保密和安全管理对于保证数据系统的安全极为重要。

10.3.1 密钥管理

密钥管理是处理密钥从产生到最终销毁的整个过程中的有关问题，包括系统的初始化及密钥的产生、存储、备份/恢复、装入、分配、保护、更新、控制、丢失、撤销和销毁等内容。设计安全的密码算法和协议并不容易，而管理密钥则更难。密钥是保密系统中最脆弱的环节，其中密钥分配和存储可能最棘手。在过去，都是通过手工作业来处理点到点通信中的问题的。随着通信技术的发展和多用户保密通信网的出现，在一个具有众多交换节点和服务节点、工作站及大量用户的大型网络中，密钥管理工作极其复杂，这就要求密钥管理系统逐步实现自动化。

在一个大型通信网络中，数据将在多个终端和主机之间进行传递。端到端加密的目

的在于使无关用户不能读取别人的信息，但这需要大量的密钥而使密钥管理复杂化。同样，在主机系统中，许多用户向同一主机存取信息，也要求彼此之间在严格的控制之下相互隔离。因此，密钥管理系统应当能保证在多用户、多主机和多终端情况下的安全性和有效性。密钥管理不仅影响系统的安全性，而且涉及系统的可靠性、有效性和经济性。类似于信息系统的安全性，密钥管理也有物理上、人事上、规程上和技术上的内容，本节主要从技术上讨论密钥管理的有关问题。

在分布式系统中，人们已经设计了用于自动密钥分配业务的几个方案。其中某些方案已被成功地使用，如 Kerberos 和 ANSI X.9.17 方案采用了 DES 技术，而 ISO-CCITT X.509 目录认证方案主要依赖于公钥技术。

密钥管理的目的是维持系统中各实体之间的密钥关系，以抗击各种可能的威胁，如：

(1) 密钥的泄漏。

(2) 密钥或公开钥的确证性 (Authenticity) 的丧失，确证性包括共享或有关于一个密钥的实体身份的知识或可证实性。

(3) 密钥或公开钥未经授权使用，如使用失效的密钥或违例使用密钥。

密钥管理与特定的安全策略有关，而安全策略又根据系统环境中的安全威胁制定。一般安全策略需要对下述几个方面做出规定：①密钥管理在技术和行政方面要实现哪些要求和所采用的方法，包括自动和人工方式；②每个参与者的责任和义务；③为支持和审计、追踪与安全有关事件需做的记录的类型。

密钥管理要借助加密、认证、签名、协议、公证等技术。密钥管理系统中常常依靠可信第三方参与的公证系统。公证系统是通信网中实施安全保密的一个重要工具，它不仅可以帮助实现密钥的分配和证实，而且可以作为证书机构、时戳代理、密钥托管理理和公证代理等。不仅可以断定文件签署时间，还可保证文件本身的真实可靠性，使签名者不能否认他在特定时间对文件的签名。在发生纠纷时可以根据系统提供的信息进行仲裁。公证机构还可采用审计追踪技术，对密钥的注册、证书的制作、密钥更新、撤销进行记录审计等。

10.3.2 密钥的种类

密钥的种类多而繁杂，但在一般通信网的应用中有基本密钥、会话密钥、密钥加密密钥、主机主密钥及双钥体制下的公钥和私钥等。几种密钥之间的关系如图 10-5 所示。

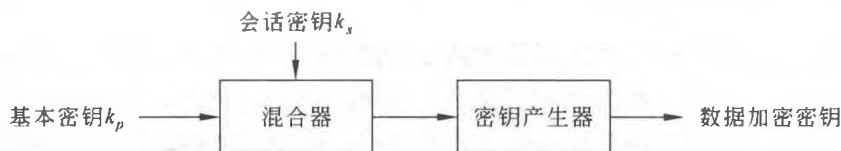


图 10-5 几种密钥之间的关系

(1) 基本密钥 (Base Key) 或称初始密钥 (Primary Key)，以 k_p 表示，它是由用户选定或由系统分配、可在较长时间（相对于会话密钥）内由一对用户专用的密钥，故又称做用户密钥 (User Key)。基本密钥既要安全，又要便于更换，能与会话密钥一起去启

动和控制某种算法所构造的密钥产生器,产生用于加密数据的密钥流。

(2) 会话密钥 (Session Key)。两个通信终端用户在一次通话或交换数据时所用的密钥,以 k_s 表示。当用于对传输的数据进行保护时,称其为数据加密密钥 (Data Encrypting Key),当用于保护文件时,称其为文件密钥 (File Key)。会话密钥的作用是使人们可以不必频繁地更换基本密钥,这有利于密钥的安全和管理。这类密钥可由用户双方预先约定,也可由系统通过密钥建立协议动态地产生并赋予通信双方,它为通信双方专用,故又称专用密钥 (Private Key)。由于会话密钥使用时间短暂且有利于安全性,它限制了密码分析者攻击时所能得到的同一密钥下加密的密文量;在密钥不慎丢失时,所泄漏的数据量有限,会话密钥只在需要时通过协议建立,从而降低了分配密钥的存储量。

(3) 密钥加密密钥 (Key Encrypting Key)。用于对传送的会话或文件密钥进行加密时采用的密钥,也称次主密钥 (Submaster Key)、辅助 (二级) 密钥 (Secondary Key) 或密钥传送密钥 (Key Transport Key),以 k_e 表示。通信网中每个节点都分配有一个这类密钥。为了安全,各节点的密钥加密密钥应互不相同。每台主机都必须存储有关到其他各主机和本主机范围内各终端所用的密钥加密密钥,而各终端只需要一个与其主机交换会话密钥时所需的密钥加密密钥,称之为终端主密钥 (Terminal Master Key)。在主机和一些密码设备中,存储各种密钥的装置应有断电保护和防窜扰、防欺诈等控制功能。

(4) 主机主密钥 (Host Master Key)。它是对密钥加密密钥进行加密的密钥,存于主机处理器中,以 k_m 表示。

单密钥除上述几种密钥外,在工作中还会碰到一些密钥。例如,用户选择密钥 (Custom Option Key),用来保证同一类密码机的不同用户使用不同的密钥;还有族密钥 (Family Key) 及算法更换密钥 (Algorithm Changing Key) 等。这些密钥的某些作用可以归入上述几类中的一类。它们主要是在不增大更换密钥工作量的条件下扩大可使用的密钥量。基本密钥一般通过面板开关或键盘选定,而用户选择密钥常要通过更改密钥产生算法来实现。例如,在非线性移存器型密钥流产生器中,基本密钥和会话密钥用于确定寄存器的初态,而用户选择密钥可决定寄存器反馈线抽头的连接。

(5) 在双钥体制下,还有公开钥和秘密钥、签名密钥和证实密钥之分。

有关密钥管理的基本论述可参阅相关文献[ISO8732 1987; Matyas 等 1991; Ford 1994; ITU-T REC X.509 1995a, 1995b, 1993; Menezes 等 1995]。

10.4

密钥生成

在现代数据系统中加密需要大量密钥,以分配给各主机、节点和用户。如何产生好的密钥是很关键的。密钥可以用手工方式产生,也可以用自动生成器产生。所产生的密钥要经过质量检验,如伪随机特性的统计检验。用自动生成器产生密钥不仅可以减少人的烦琐劳动,而且还可以消除人为差错和有意泄漏,因而更加安全。自动生成器产生密钥算法的强度非常关键。

10.4.1 密钥选择对安全性的影响

1. 使密钥空间减小

例如 56b (10^{16}) 的 DES 在软件加密下, 若只限用小写字母和数字, 则可能的密钥数仅为 10^{12} 。在不同的密钥空间下可能的密钥数如表 10-1 所示。

2. 差的选择方式易受字典式攻击

攻击者首先从最容易之处着手, 如英文字母、名字、普通的扩展等, 这称为字典式攻击 (Dictionary Attack), 25% 以上的口令可由此方式攻破, 具体方法如下:

- (1) 本人名、首字母、账户名等有关个人信息。
- (2) 从各种数据库采用的字试起。
- (3) 从各种数据库采用的字的置换试起。
- (4) 从各种数据库采用的字的大写置换试起, 如 Michael 和 mIchael 等。
- (5) 外国人用外国文字试起。
- (6) 试对等字。

这种攻击方法在攻击一个多用户的数据或文件系统时最有效, 上千人的口令中总会有几个口令是较弱的。

表 10-1 密钥空间

	4b	5b	6b	7b	8b
小写字母 (26)	4.6×10^5	1.2×10^7	3.1×10^8	8.0×10^9	2.1×10^{11}
小写字母+数字	1.7×10^6	6.0×10^7	2.2×10^9	7.8×10^{10}	2.8×10^{12}
62 字符	1.5×10^7	9.2×10^8	5.7×10^{10}	3.5×10^{12}	2.2×10^{12}
95 字符	8.1×10^7	7.7×10^9	7.4×10^{11}	7.0×10^{13}	6.6×10^{15}
128 字符	2.7×10^8	3.4×10^{10}	4.4×10^{12}	5.6×10^{14}	7.2×10^{16}
256 字符	4.3×10^9	1.1×10^{12}	2.8×10^{14}	7.2×10^{16}	1.8×10^{19}

10.4.2 好的密钥

(1) 真正随机、等概率, 如掷硬币、掷骰子等。

(2) 避免使用特定算法的弱密钥。

(3) 双钥系统的密钥更难以产生, 因为必须满足一定的数学关系。

(4) 为了便于记忆, 密钥不能选得过长, 而且不可能选完全随机的数串, 要选用易记而难猜中的密钥。

(5) 采用密钥揉搓或杂凑技术, 将易记的长句子 (10~15 个英文字的通行短语), 经单向杂凑函数变换成伪随机数串 (64b)。

10.4.3 不同等级的密钥产生的方式不同

(1) 主机主密钥是控制产生其他加密密钥的密钥, 一般都长期使用, 所以其安全性

至关重要，故要保证其完全随机性、不可重复性和不可预测性。任何机器和算法所产生的密钥都有周期性和被预测的危险，不适合作为主机主密钥。主机主密钥的数量小，可用投硬币、掷骰子、噪声产生器等方法产生。

(2) 密钥加密密钥可用安全算法、二极管噪声产生器、伪随机数产生器等产生。如在主机主密钥控制下，由 X.9.17 安全算法生成。

(3) 会话密钥、数据加密密钥（工作密钥）可在密钥加密密钥控制下通过安全算法产生。

10.5 密钥分配

密钥分配方案研究的是密码系统中密钥的分发和传送问题。从本质上讲，密钥分配是使用一串数字或密钥对通信双方所交换的秘密信息进行加密、解密、传送等操作，以实现保密通信或认证签名等。

10.5.1 基本方法

通信双方可通过 3 种基本方法实现秘密信息的共享：一是利用安全信道实现密钥传递；二是利用双钥体制建立安全信道传递；三是利用特定的物理现象（如量子技术）实现密钥传递。下面分别对这 3 种方法进行详细介绍。

1. 利用安全信道实现密钥传递

这种方法由通信双方直接面议或通过可靠信使递送密钥。传统的方法是通过邮递或信使护送密钥。密钥可用打印、穿孔纸带或电子形式记录。这种方法的安全性完全取决于信使的忠诚和素质，所以信使必须精心挑选，即便如此，仍很难完全消除信使被收买的可能性。这种方法成本很高，薪金不能太低，否则会危及安全性。有人估计此项支出可达整个密码设备费用的三分之一。这种方法一般可保证密钥传递的及时性和安全性，偶尔会出现丢失、泄密等。为了减少费用，可采用分层方式传递密钥，信使只传递密钥加密密钥，而不去传递大量的数据加密密钥。这既减少了信使的工作量（从而大大降低了费用），又克服了用一个密钥加密过多数据的问题。当然这不能完全克服信使传送密钥的缺点。由于这种方法成本高，所以只适用于高安全级密钥的传递，如主密钥的传递。

还可以采用某种更隐蔽的方法传送密钥，如将密钥分拆成几部分分别递送，如图 10-6 所示。除非敌手可以截获密钥的所有部分，只截获部分密钥毫无用处。因此，一般情况下此法有效。这种方法只适用于传递少量密钥的情况，如主密钥、密钥加密密钥等，且收方收到密钥后要妥善保存。

用主密钥对会话密钥加密后，可通过公用网传送，或用公钥密钥分配体制实现。如果采用的加密系统足够安全，则可将其看做是一种安全信道。

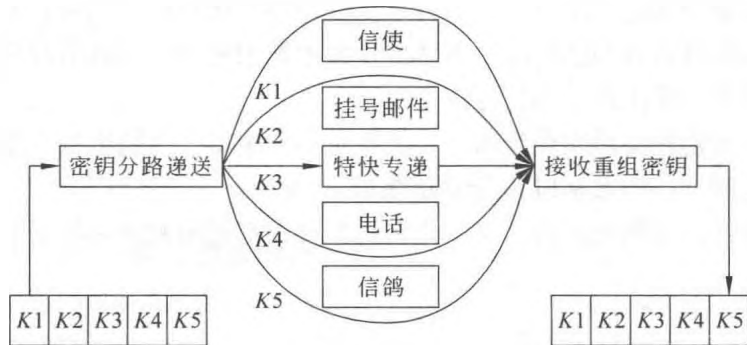


图 10-6 密钥分路递送

2. 利用双钥体制建立安全信道传递

由于 RSA、Diffie-Hellman 等双钥体制运算量较大，所以不适合用于对语音、图像等实时数据进行加解密。但是，双钥体制却非常适合用来进行密钥的分配。我们知道，双钥体制使用两个密钥，一个是公钥，一个是私钥。公钥是公开的，通信一方可采用公钥对会话密钥加密，然后再将密文传递给另一方。收方接收到密文后，用其私钥解密即可获得会话密钥。当然，这里存在接收方假冒他人发布公钥的问题。为了确保接收方所发布公钥的真实性，发送方可以通过验证接收方的数字证书来获得可信的公钥。这需要设计专门的密码协议来实现密钥的密钥分配与交换。

Newman 等于 1986 年提出的 SEEK (Secure Electronic Exchange of Keys) 密钥分配体制系统采用 Diffie-Hellman 和 Hellman-Pohlig 密码体制实现。这一方法已被用于美国 Cylink 公司的密码产品中。Gong 等提出一种用 $GF(p)$ 上的线性序列构造的公钥分配方案。

也可通过可信密钥管理中心 (KDC) 进行密钥分配，如采用 PEM、PKI/CA 等技术分配密钥。

3. 利用量子技术实现密钥传递

量子信息将成为后摩尔时代的新技术，它是量子物理与信息科学相融合的新兴交叉学科。量子信息以量子态作为信息单元，信息从产生、传输、处理和检测等均服从量子力学的规律。基于量子力学的特性，诸如叠加性、非局域性、纠缠性、不可克隆性等，量子信息可以实现经典信息无法做到的新的信息功能，突破现有信息技术的物理极限。

量子信息以光子的量子态表征信息。如果约定光子偏振态的圆偏振代表“1”，线偏振代表“0”。量子比特与经典比特的区别如图 10-7 所示。

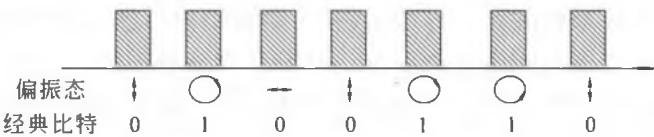


图 10-7 量子比特与经典比特的区别

基于量子密码的密钥分配方法是利用物理现象实现的。量子密码可以确保量子密钥分配的安全性，与一次一密算法的不可破译性相结合，可提供不可窃听、不可破译的安

全保密通信。密码学的信息理论研究指出,通信双方 A 到 B 可通过先期精选、信息协调、保密增强等密码技术来实现使 A 和 B 共享一定的秘密信息,而窃听者对其却一无所知。

10.5.2 密钥分配的基本工具

认证技术和协议技术是分配密钥的基本工具。认证技术是安全分配密钥的保障,协议技术是实现认证和密钥分配必须遵循的流程。有关密钥分配的各种协议将在本章后面做介绍。

10.5.3 密钥分配系统的基本模式

小型网可采用每对用户共享一个密钥的方法,这在大型网中是不可实现的。一个有 N 个用户的系统,为实现任意两个用户之间的保密通信,需要生成和分配 $N(N-1)/2$ 个密钥才能保证网中任意两个用户之间的保密通信。随着系统规模的加大,复杂性剧增,例如 $N=1000$ 时,就需要有约 50 万个密钥进行分配、存储等。为了降低复杂度,人们常采用中心化密钥管理方式,将一个可信的联机服务器作为密钥分配或转递中心(KDC 或 KTC)来实现密钥分配。图 10-8 给出几种密钥分配的基本模式,其中 k 表示 A 和 B 共享密钥。

(1) 图 10-8 (a) 中由 A 直接将密钥送给 B ,利用 A 与 B 的共享基本密钥加密实现。

(2) 图 10-8 (b) 中 A 向 KDC 请求发放与 B 通信用的密钥, KDC 生成 k 传给 A ,并通过 A 转递给 B ,或 KDC 直接给 B ,利用 A 与 KDC 和 B 与 KDC 的共享密钥实现。

(3) 图 10-8 (c) 中 A 将与 B 通信会话密钥 k 送给 KTC, KTC 再通过 A 转递给 B ,或 KTC 直接送给 B ,利用 A 与 KTC 和 B 与 KTC 的共享密钥实现。

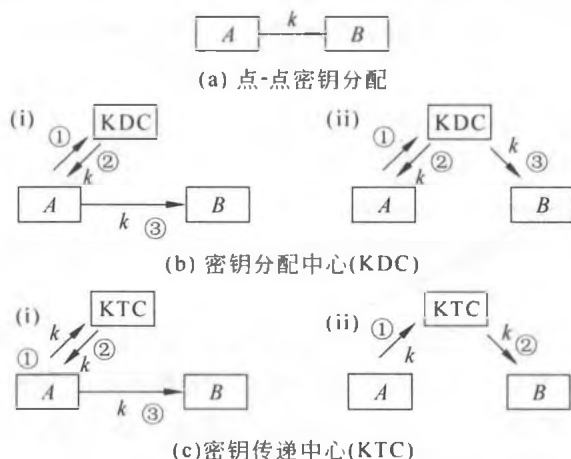


图 10-8 密钥分配的基本模式

由于有 KDC 或 KTC 参与,各用户只须保存一个与 KDC 或 KTC 共享的较长期使用的密钥但要承担的风险是中心的可信程度,中心节点一旦出问题将极大地威胁系统的安全性。

10.5.4 可信第三方 TTP

可信第三方 (Trusted Third Parties, TTP) 可按协调 (In Line)、联机 (On Line) 和

脱机（Off Line）3种方式参与。在协调方式下， T 是一个中间人，为 A 与 B 之间通信提供实时服务；在联机方式下， T 实时参与 A 和 B 每次协议的执行，但 A 和 B 之间的通信不必经过 T ；在脱机方式下， T 不实时参与 A 和 B 的协议，而是预先向 A 和 B 提供双方执行协议所需的信息。可信第三方的工作模式如图10-9所示。

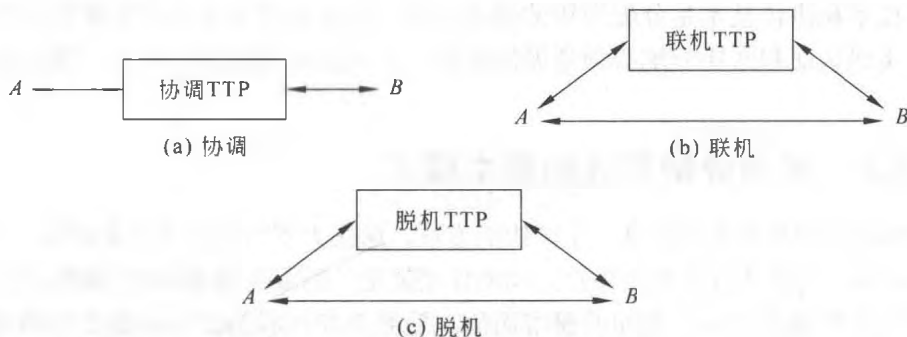


图 10-9 可信第三方的工作模式

当 A 和 B 属于不同的安全区域时，协调方式特别重要。证书发放管理机构常采用脱机方式。脱机方式对计算资源的要求较低，但在撤销权宜上不如其他两种方式方便。

TTP 可以是一个公钥证书颁发机构（CA），利用 PKI 技术颁发证书。它包括下述几个组成部分，如图 10-10 所示。

(1) 证书管理机构（Certification Authority, CA）。负责公钥的建立、可靠性的证实。在基于证书的体制中，CA 通过对公钥的签名将证书赋予不同用户，并负责证书序号和证书吊销的管理。

(2) 用户名服务器（Name Server）。负责管理用户名字的存储空间，保持其唯一性。

(3) 注册机构（Registrator Authority）。对可由安全区内成员的唯一名所区分的合法实体负责。用户注册一般包括与实体有关的密钥材料。

(4) 密钥生成器。建立公钥/私钥对（以及单钥体制的密钥、通行字等），可以是用户的组成部分，也可作为 CA 的组成部分，或是一个独立的可信赖系统。

(5) 证书检索。用户可以查阅的证书数据库或服务器，CA 可以向它补充证书，用户只可以管理有关它自己的数据项。

TTP 还可提供如下功能：

(1) 密钥服务器。负责建立各有关实体的认证密钥和会话密钥，用 KDC 和 KTC 表示。

(2) 密钥管理设备。负责密钥的生成、存储、建档、审计、报表、更新、撤销及管理证书业务等。

(3) 密钥查阅服务。提供用户根据权限访问与其有关的密钥信息。

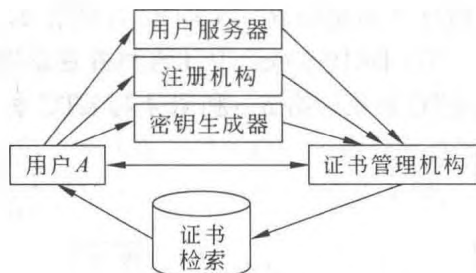


图 10-10 公钥证书机构业务

(4) 时戳代理。确定与特定文件有关的时间信息。

(5) 仲裁代理。验证数字签名的合法性, 支持不可否认业务、权益转让及某一陈述的可信性。

(6) 托管代理。接受用户所托管的密钥, 提供密钥恢复业务。

不同的系统可能需要不同可信度的 TTP, 可信度一般分为 3 级: 一级表示 TTP 知道每个用户的密钥; 二级表示 TTP 不知道用户的密钥, 但 TTP 可制作假的证书而不会被发现; 三级表示 TTP 不知道用户的密钥, TTP 所制作的假证书可以被发现。

10.5.5 密钥注入

(1) 主机主密钥的注入。主密钥由可信的保密员在非常安全的条件下装入主机, 一旦装入, 就不能再读取。检验密钥是否已正确地注入设备, 需要有可靠的算法。例如, 可选一随机数 R_N , 并以主密钥 K_m 加密得到 $E_m(R_N)$, 同时计算出 K_m 的一个函数 φ 的值 $\varphi(K_m)$ (φ 可为 Hash 函数)。装入 K_m 后, 若它对 R_N 加密结果及 $\varphi(\bullet)$ 值与记录的值相同, 则表明 K_m 已正确装入主机。

要防电磁辐射、防窜扰、防人为出错, 且要存入主机中不易丢失数据的存储器件中。

(2) 终端机主密钥的注入。在安全环境下, 由可信赖的保密员进行装入终端。当终端机数量较多时, 可用专用密钥注入工具 (如密钥枪) 实施密钥注入操作。密钥注入后就不能再读取。密钥注入后要验证装入数据的正确性, 可以通过与主机联机检验, 也可脱机检验。

(3) 会话密钥的获取。例如, 主机与某终端通信, 主机产生会话密钥 K_s , 以相应终端主密钥 K_t 对其进行加密得 $E_{K_t}(K_s)$, 将其送给终端机。终端机以 K_t 进行解密, 得 K_s , 送至工作密钥产生器, 去生成工作密钥, 如图 10-11 所示。

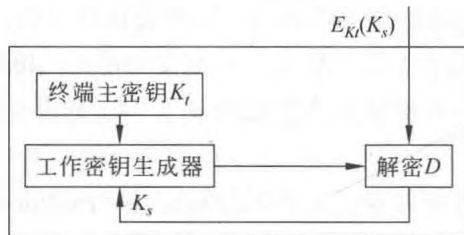


图 10-11 会话密钥的生成

10.6

密钥的证实

在密钥分配过程中, 需要对密钥进行认证, 以确保密钥被正确无误地送给了指定的用户, 防止伪装信使递送假密钥套取信息, 并防止密钥分配中的差错。在信使递送密钥时, 他需要相信信使, 并需要对密钥进行确证。例如, 采用指纹法比用 ID 卡更好些, 而

让信使递送加密后的密钥可能要安全些。若密钥通过加密密钥送来，他得相信只有对方 B 才有此密钥；若 B 用数字签名协议签署该密钥，则当 A 证实此密钥时他得相信公共数据库提供的 B 的公钥；若密钥分配中心（KDC）签署了 B 的公钥， A 必须相信 KDC 给它的公钥复件未被篡改。这些都需要对公钥认证，因为任何可从公钥本得到某用户公钥的人，都可向他送假密钥以求进行保密通信。因此，必须使接收密钥的用户能够确认出送密钥的是谁。采用公钥签名法可以解决这个问题。虽然这种方法能够证实递送密钥者，但还不能确知谁收到了密钥，伪装者也可以公布一个公钥冒充合法用户要求进行保密通信。除非这一合法用户与其要通信的人进行接触，或合法用户自己公开声明其公钥，否则安全性就无保障。SEEK 法也存在着类似的问题。因此，采用这些电子分配密钥方法时也要特别小心，需精心地设计分配密钥的安全协议。

现实世界可能有各种欺诈，若攻击者控制了 A 向外联系的网络，他可伪装成 B 发送一个加密并签名的消息给 A 。当 A 想访问公钥数据库以证实是否为 B 的签名时，攻击者可用他的公钥来代替 B 的公钥，且可伪造一个假的 KDC，并将真正的 KDC 的公钥换成他自己伪造的公钥。此方法在理论上是可行的，但实行起来很复杂。采用数字签名和可信赖的 KDC，使得攻击者以一个密钥代换另一个密钥更为困难。 A 不能低估攻击者控制他的整个网络的能力，但 A 可以相信要做此事所需的资源比攻击者攻击大多数现有系统所需要的资源要多得多。 A 可通过电话证实 B 的公钥，即根据熟悉的声音认证 A 所得的密钥为 B 的。若密钥太长，可用单向 hash 函数技术证实密钥。

有时不仅要证实所拥有公钥的人是谁，而且还要证实在以前某个时候，如去年他是否属于同一个人。银行收到一个提款签名时，一般不太关心谁提款，而主要关心他是否是最初存款的人。

除了要对密钥的主权人进行认证外，还要对密钥的完整性进行认证。密钥在传送过程中可能出错，致使千百万位数据不能解密，因此要认真对待。可采用检错、纠错技术，如校验和；以密钥对全 0 或全 1 常量加密，将密文的前 2~4b 和密钥一起通过安全方式送出。接收端做同样的事，并检验加密结果的前 2~4b 是否相同。若相同，则密钥出错概率为 $2^{-16} \sim 2^{-32}$ 。

为了防止重放攻击，系统需要保证密钥的新鲜性（freshness），常用加载时戳、流水作业号以及累加器值不断更新等技术来保证[Denning 等 1981]。下面具体介绍几种密钥证实技术。

10.6.1 单钥证书

单钥证书可以向 KTC 提供一种工具，KTC 利用此证书可以避免对用户秘密的安全数据库维护，在多服务器下复制这类数据库，或根据传送要求从库中检索这类密钥。对于用户 A ，他有与 TTP 共享的密钥 K_{AT} ，以 TTP 的密钥 KT 对 K_{AT} 和用户 A 的身份加密得 $E_{KT}(K_{AT}, A, L)$ ，就可作为单钥证书（Symmetric Key Certificates），其中 L 为使用期限。TTP 将 $E_{KT}(K_{AT}, A, L)$ 发给 A ，作为用户使用密钥 K_{AT} 的合法性证据，以 $SCert_A$ 表示。TTP

不需要保存 K_{A_T} ，只要保存 K_T 即可；需要时，如 A 要与 B 进行保密通信，可首先向 B 索取或从密钥数据库查找出证书 $SCert_B = E_{K_T}(K_{B_T}, B, L)$ ，而后向 TTP 送出

$$SCert_A, E_{K_T}(B, M), SCert_B$$

即可按有关协议实现会话密钥建立。其中， M 是秘密消息，也可作为会话密钥。TTP 需采用联机方式，以使用其主密钥进行解密。密钥数据库可以由各用户名及相应证书组成。

有关单钥证书可参阅相关文献[ISO/IEC11770 1996b]。

10.6.2 公钥的证实技术

公钥的证实技术有下述几种方法：

(1) 通过可信赖信道实现点-点递送。通过个人直接交换或直通信道（信使、挂号邮件）直接得到有关用户的可靠公钥，适用于小的封闭系统或不经常用的（如一次性用户注册）场合。通过不安全信道交换公钥和有关信息要经过认证和完整性检验。

该方法的缺点是不太方便、耗时，每个新成员都要通过安全信道预先分配公钥，不易自动化，可信赖信道成本高等。

(2) 直接访问可信赖公钥文件（公钥注册本）。利用一个公钥数据库记录系统中每个用户名和相应的可靠的公钥。可信赖者管理公钥的注册，用户通过访问公钥数据库获取有关用户的公钥；在远程访问时要经过不安全信道，须防范窃听；为了防范主动攻击需要利用认证技术实施公钥库的注册和访问。

(3) 利用联机可信赖服务器。可信赖服务器可以受用户委托查询公钥库中存储的可信公钥，并在签署后传送给用户。用户用服务器的公钥证实其所签的消息。此方法的缺点是要求可信赖服务器联机工作，从而在业务忙时成为瓶颈，而且每个用户要先与可信赖服务器通信后再与所要的用户通信。

(4) 采用脱机服务器和证书。每个用户都可与脱机可信赖的证书机构（CA）进行一次性的联系，向其进行公钥注册并获得一个由 CA 签署的公钥证书。各用户通过交换自己的公钥证书，并用 CA 的公钥进行验证，即可提取出所要的可信公钥。

(5) 采用可隐含保证公钥参数真实性的系统。这类系统有基于身份的系统，以及通过算法设计、公钥参数受到修正时可以检测、非泄漏失败（Non Compromising Failure）等密码技术实现的隐式证实密钥的系统。

有关内容可参阅[Diffie 等 1976]。

10.6.3 公钥认证树

认证树（Authentication Trees）可以提供一种可证实公开数据的真实性的方法，以树形结构结合合适的杂凑函数、认证根值等实现。认证树可用于下述场合：

(1) 公钥的认证（是另一种公钥证书），由可信赖第三方建立认证树，其中包含用户的公钥，可实现大量密钥的认证。

(2) 实现可信赖时戳业务，由可信赖第三方建立认证树，用类似于（1）的方法实现。

(3) 用户合法参数的认证，由某个用户建立认证树，并以可证实真实性的方式公布

其大量的公开合法的参数，如在一次性签名体制中所用的参数。

下面以二元树为例说明。二元树由节点和有向线段组成，如图 10-12 所示。二元树的节点有 3 种：根节点，有左右两个朝向它的线段；中间节点，有 3 个线段，其中有两个朝向它，一个背离它；端节点（叶），只有一个背离它的线段。

由一个中间节点引出的左右两个相邻节点称为该中间节点的子节点，称此中间节点为相应两个子节点的父节点。从任一非根节点到根节点有一条唯一的通路。

下面介绍如何构造认证树。考察一个有 t 个可信的公开值 $Y_1, Y_2, \dots, Y_t$ ，按下述方法构造一个认证树：以唯一公开值 Y_i 标示第 i 个端节点；以杂凑值 $h(Y_i)$ 表示离去的线段；上一级中间节点若其左右两边都有下级节点，则以其相应杂凑值链接后的杂凑值表示其离去的线段。如 $H_5 = h(H_1 \parallel H_2)$ ，以此类推直至出现根节点，如图 10-13 所示。

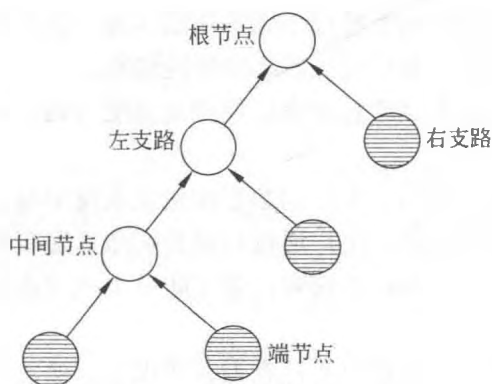


图 10-12 二元树

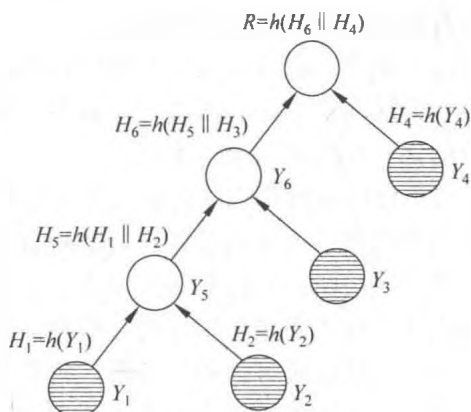


图 10-13 认证树

认证方法如下，以图 10-13 为例说明对密钥的证实。

公开值 Y_1 可以由标示序列 $h(Y_2), h(Y_3), h(Y_4)$ 提供认证。首先计算 $h(Y_1)$ ，然后计算 $H_5 = h(H_1 \parallel H_2)$ ，再计算 $H_6 = h(H_5 \parallel H_3)$ ，最后计算 $h(H_6 \parallel H_4)$ ，若 $h(H_6 \parallel H_4) = R$ ，则接受 Y_1 为真；否则就拒绝。

若实体 A 认证 t 个公开值 $Y_1, Y_2, \dots, Y_t$ ，可以将每个值向可信赖第三方注册。当 t 很大时，将大大增加存储量，采用认证树则仅需要向第三方注册一个根值。

若实体 A 的公钥值 Y_i 相应于认证树的一个端节点， A 若向 B 提供 A 的此公钥，允许 B 对 Y_i 进行证实，则 A 必须向 B 提供 Y_i 到根节点通路上的所有杂凑值。 B 就可经计算杂凑最终证明 Y_i 的真伪。类似地可以以验证签名代替计算杂凑函数。

为了实现方便，应使认证二元树的最长通路极小化，此时各路径长度最多相差一个支路。路径长度约为 $\log_2 t$ ，其中 t 是公开值的个数。当需要改变或增加或减少一个公开值 Y_i 时，就要对有关路径中的表示杂凑值重新进行计算。

10.6.4 公钥证书

公钥证书（Public Key Certificate）是一个载体，用于存储公钥。可以通过不安全媒体安全地分配和转递公钥，使一个实体的公钥可被另一个实体证实而能放心地使用。此

外, X.509 v3 中还描述了用于权限管理的属性证书 (Attribute Certificates)。有关内容请参阅第 9 章。

10.6.5 基于身份的公钥系统

基于身份 ID (identity) 的系统类似于前述的普通公钥系统, 它包含一个秘密传递变换和一个公开的变换。但用户没有一个显式公钥, 而是以用户公开可利用的身份 (用户名、网址、地址等) 替代公钥 (或由它构造公钥)。这类公开可利用的信息唯一地限定了用户, 能够作为用户的身份信息, 具有不可否认性。

基于身份的密钥系统是一种非对称系统, 其中每个实体的公开身份信息 (唯一性和真实性) 起着它的公钥的作用, 作为可信赖者 T 的输入的组成部分, 用于计算实体专用密钥时不仅要用该实体的身份信息, 而且还要用只有 T 知道的一些特殊信息 (如 T 的密钥)。这样可以防止伪造和假冒, 保证只有 CA 能够根据实体的身份信息为实体建立合法的专用密钥。类似于公钥证书系统, 基于 ID 的系统中的公开可利用数据也需要通过密码变换加以保护。有时除了 ID 数据外, 还需要一些由系统定义的有关实体 A 的辅助数据 D_A 。图 10-14 给出了基于 ID 的系统原理图。

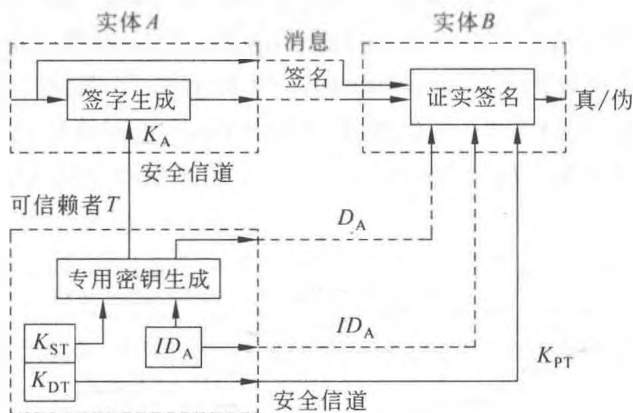


图 10-14 基于 ID 的公钥签名系统

图 10-14 中 ID_A 为实体 A 的身份数据, D_A 是辅助公开数据 (由 T 定义的与 ID_A 和 A 密钥有关), K_{PT} 是 T 的公开钥, K_{ST} 是 T 的密钥, 由三元组 (D_A, ID_A, K_{PT}) 可以推出 A 的公开钥, 从而可以验证 A 的签名。与公钥证书不同的是它传送的不是公钥, 而是可以导出公钥的一些有关身份的信息。前者称为显式 (explicit) 证书系统, 后者称为隐式 (implicitly) 证书系统。图 10-14 给出的是一个基于身份的签名系统。同样, 它可以构造基于身份的实体认证、密钥建立、加密等系统。

基于 ID 的系统优点是: 无须预先交换对称密钥或公钥; 无须一个公钥本 (公钥或证书数据库); 只在建立阶段需要可信赖机构提供服务。其缺点是要求实体身份数据 ID_A 。基于身份系统的初衷是要去掉公钥的传送, 以身份信息实现非交互作用协议。 D_A 在密钥协商和以另一实体的公钥加密系统中较为重要, 而在签名和识别系统中就不大重要, 这是因为申请公钥人在接收消息之前不会需要申请者的公钥, 此时不难提供 D_A 。而基于 ID 的系统在 IC 卡中有实用价值。Shamir [Shamir 1984] 最早提出基于 ID 的概念, 有关研究

可参阅相关文献[Maurer 等 1991, 1992]。

10.6.6 隐式证实公钥

在隐式证实公钥的系统中，不是直接传送用户的公钥，而是传送可以从中重构公钥的数据，如图 10-15 (a) 所示。

隐式证实公钥系统应实现下述要求：

- (1) 实体可以由其他实体从公开数据重新构造。
- (2) 重构公钥的公开数据中，包含与可信赖方 T 有关的公开（如系统）数据、用户实体的身份（或识别信息，如名字和地址等），以及各用户的辅助公开数据。
- (3) 重构公钥的完整性虽不是可直接证实的，但“正确”的公钥只能从可信赖用户的公开数据恢复。
- (4) 系统设计要保证攻击者在不知道 T 的密钥条件下，要从用于重构的公开数据推出实体的密钥在计算上是不可行的。

隐式证实公钥可分为两类。一类是基于身份的公钥（Identity Based Public Keys），各实体 A 的密钥由可信赖方 T 根据 A 的识别信息 ID_A ， T 的秘密钥 K_{ST} ，以及由 T 预先给定的有关 A 的用户特定重构公开数据 R_A 计算，并通过安全信道送给 A ，如图 10-15 (b) 所示。另一类是自证实公钥（Self-certified Public Keys），各实体 A 自行计算其密钥 K_{SA} 和公钥 K_{PA} ，并将 K_{PA} 传送给 T 。 T 根据 A 的公钥 K_{PA} 的识别信息 ID_A 和 T 的密钥 K_{ST} ，计算出 A 的重构公开数据，如图 10-15 (c) 所示。第 1 类对 T 的可信赖程度的要求远高于第 2 类。

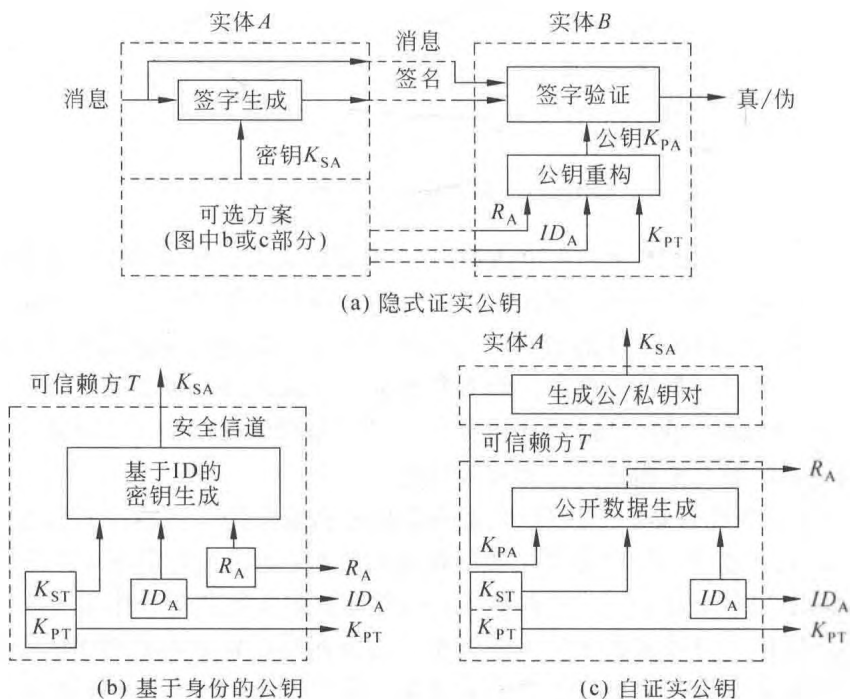


图 10-15 隐式证实公钥系统

隐式证实公钥较公钥证书的优越之处在于降低对所需的存储空间的要求（签名的证书需要较多存储），降低了计算量（证书要求对签名进行验证），降低了通信量（基于身份或预先知道身份时）。但重构公钥也需要进行计算，而且还要求辅助的重构公开数据。

有关研究可参阅相关文献[Brands 1995a]。

10.7 密钥的保护、存储与备份

10.7.1 密钥的保护

密钥的安全保密是密码系统安全的重要保证，保证密钥安全的基本原则除了在有安全保证的环境下进行密钥的产生、分配、装入及存储于保密柜内备用之外，密钥绝不能以明文形式出现。

（1）**终端密钥的保护**。可用二级通信密钥（终端主密钥）对会话密钥进行加密保护。终端主密钥存储于主密钥寄存器中，并由主机对各终端主密钥进行管理。主机和终端之间就可用共享的终端主密钥保护会话密钥的安全。

（2）**主机密钥的保护**。主机在密钥管理上担负着更繁重的任务，因而也是对手攻击的主要目标。在任意给定的时间内，主机可有几个终端主密钥在工作，因而其密码装置需为各应用程序所共享。工作密钥存储器要由主机施以优先级别进行管理加密保护，称此为主密钥原则。这种方法将对大量密钥的保护问题化为仅对单个密钥的保护问题。在有多台主机的网络系统中，为了安全起见，各主机应选用不同的主密钥。有的主机采用多个主密钥对不同类密钥进行保护。例如，用主密钥 0 对会话密钥进行保护；用主密钥 1 对终端主密钥进行保护；而网络中传送会话密钥时所用的加密密钥为主密钥 2。3 个主密钥可存放于 3 个独立的存储器中，通过相应的密码操作进行调用，可视为工作密钥对其所保护的密钥加密、解密。这 3 个主密钥也可由存储于密码器件中的种子密钥（Seed Key）按某种密码算法导出，以计算量来换取存储量的减少。此法不如前一种方法安全。除采用密码方法外，还必须和硬件、软件结合起来确保主机主密钥的安全。

（3）**密钥分级保护管理法**。图 10-16 和表 10-2 都给出了密钥的分级保护结构，从中可以清楚看出各类密钥的作用和相互关系。由此可见，大量数据可以通过少量动态产生的数据加密密钥（初级密钥）进行保护；而数据加密密钥又可由更少量的、相对不变（使用期较长）的密钥（二级）或主机主密钥 0 来保护；其他主机主密钥（1 和 2）用来保护三级密钥。这样，只有极少数密钥以明文形式存储在有严密物理保护的主机密码器件中，其他密钥则以加

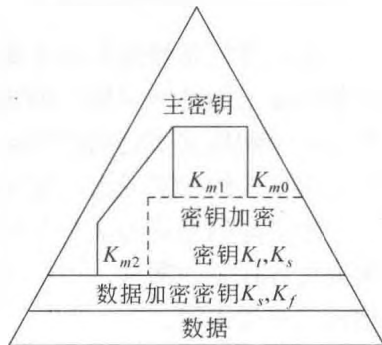


图 10-16 密钥的分级保护

密后的密文形式存于密码器之外的存储器中，因而大大简化了密钥管理，并增强了密钥的安全性。

表 10-2 密钥分级结构

密钥种类	密 钥 名	用 途	保护对象
密钥加密密钥	主机主密钥 $0=K_{m0}$ 主机主密钥 $1=K_{m1}$ 主机主密钥 $2=K_{m2}$	对现用密钥或存储在主机内的密钥加密	初级密钥 二级密钥 二级密钥
	终端主密钥 K_t （或二级通信密钥） 文件主密钥 K_s （或二级文件密钥）	对主机外的密钥加密	初级通信密钥 初级文件密钥
数据加密密钥	会话（或初级）密钥 K_s 文件（或初级）密钥 K_f	对数据加密	传送的数据 存储的数据

10.7.2 密钥的存储

密钥存储时必须保证密钥的机密性、认证性和完整性，防止泄漏和被修改。下面介绍几种可行的方法。

（1）每个用户都有一个用户加密文件备用。由于只与一个人有关，由个人负责，因而是最简易的存储办法。例如，在有些系统中，密钥存于个人的大脑中，而不存于系统中；用户要记住它，并且要在每次需要时输入它，如在 IPS 中，用户可直接输入 64b 密钥。

（2）存入 ROM 钥卡或磁卡中。用户将自己的密钥输入系统，或者将卡放入读卡机或计算机终端。若将密钥分成两部分，一半存入终端，另一半存入如 ROM 钥卡上。一旦 ROM 钥卡丢失也不至于泄漏密钥。终端丢失时同样不会丢失密钥。

（3）难以记忆的密钥可用加密形式存储，利用密钥加密密钥来做。如 RSA 的密钥可用 DES 加密后存入硬盘，用户须有 DES 密钥，运行解密程序才能将其恢复。

（4）若利用确定性算法来生成密钥（密码上安全的 PN 数生成器），则每次需要时，用易于记忆的口令启动密钥产生器对数据进行加密。但这一方法不适用于文件加密，原因是过后解密时，还得用原来的密钥，因此必须要存储该密钥。

10.7.3 密钥的备份

对密钥进行备份是非常必要的。如一个单位，密钥由某人主管，一旦发生意外，如何才能恢复已加密的消息？因此密钥必须有备份，交给安全人员放在安全的地方保管；将各文件密钥用主密钥加密后封存。当然，必要条件是安全员是可信的，他不会逃跑、不会出卖别人的密钥或滥用别人的密钥。

一个更好的解决办法是采用共享密钥协议。这种协议将一个密钥分成几部分，每个有关人员各保管一部分，但任何一个部分都不起关键作用，只有将这些部分收集起来才能构成完整的密钥。

10.8

密钥的泄漏、吊销、过期与销毁

10.8.1 泄漏与吊销

密钥的安全是协议、算法和密码技术设备安全的基本条件。密钥一旦泄漏，如丢失或被窃等，安全保密就无从谈起。唯一的补救办法是及时更换密钥。

若密钥由 KDC 来管理，则用户要及时通知 KDC 撤销此密钥；若无 KDC，则应及时告诉可能与其进行通信的人，以后用此密钥通信的消息无效且可疑，本人概不负责。当然，声明要加上时戳。

当用户不确知密钥是否已经泄漏或泄漏的确切时间时，问题就更加复杂。用户可能要撤回合同以防别人用其密钥签署另一份合同来替换它，这将引起争执，需诉诸法律或公证机构裁决。

个人专用密钥丢失要比密钥丢失更加严重，因为密钥要定期更换，而专用密钥使用期更长。若丢失了专用密钥，别人就可用它在网上阅读函件、窃听通信和签署合同等。而且在公用网上，丢失的专用密钥传播得极快。公钥数据库应当在专用密钥丢失后，立即采取行动，以使损失最小化。

10.8.2 密钥的有效期

密钥的有效期或保密期（Cryptoperiod）是指合法用户可以合法使用密钥的期限。

密钥使用期限必须适当限定。因为密钥使用期越长，泄漏的机会就越大，一旦泄漏，带来的损失也越大（涉及更多文件、信息、合同等）；由于使用期长，用同一密钥加密的材料就越多，因而更容易被分析破译。

策略：不同的密钥有不同的有效期。①短期密钥（Short Term Keys）如会话密钥，使用期较短，具体期限由数据的价值、给定周期内加密数据的量来确定。如 Gb/s 的信道密钥要比 9600b/s Modem 线路的密钥更换得更频繁，一般会话密钥至少一天换一次。②密钥加密密钥属于长期性密钥（Long Term Keys），不需要经常更换，因为用其加密的数据很少，但它很重要，一旦丢失或泄漏，影响极大。这种密钥一般一个月或一年更换一次。③用于加密数据文件或存储数据的密钥不能经常更换，因为文件可能在硬盘中存储数月或数年才会再被访问，若每天更换新密钥，就得将其调出解密而后再以新密钥加密，这不会带来太多好处，因为文件将多次以明文形式出现，给攻击者更多的机会。文件加密密钥的主密钥应保管好。④公钥密码的密钥，它的使用期限由具体应用来确定。用于签名和身份验证的密钥的期限可能以年计（甚至终生），但一般只用一两年。过期的密钥还要保留，以备证实时使用。

10.8.3 密钥销毁

不用的旧密钥必须销毁，否则可能造成损害。别人可利用旧密钥来读原来曾用它加

密的文件，或者用它来分析密码体制。密钥必须安全地销毁，例如，可采用高质量碎纸机处理记录密钥的纸张，使攻击者不可能通过收集旧纸片来寻求有关秘密信息。对于硬盘、EEPROM 中的存储数据，要进行多次重写。

潜在的问题：存于计算机中的密钥，很容易被多次复制并存储于计算机硬盘中的不同位置。采用防篡改器件能自动销毁存储在其中的密钥。

10.9

密钥控制

密钥控制是对密钥的使用进行限制，以保证按预定的方式使用密钥。可以赋予密钥的控制信息有：密钥的主权人、密钥的合法使用期限、密钥的识别符、预定的用途、限定的算法、预定使用的系统或环境或密钥的授权用户、与密钥注册和证书有关的实体名字、密钥的完整性校验（作为密钥真实性的组成部分）。

为了密码的安全，避免一个密钥有多种应用，这就需要对密钥实施隔离（separation），做物理上的 10.10 节中密钥控制或密码技术上的保护，以限制密钥的授权使用。密钥标签（tags）、密钥变形（varionts）、密钥公证（nortarization）、控制矢量（control vectors）等，都是为了对密钥进行隔离所附加的控制信息的方式。

单钥体制中的密钥控制技术：

（1）**密钥标签**。它以标记方式限定密钥的用途，如数据加密密钥、密钥加密密钥等。它由比特矢量或数据段实现，其中还标有使用期限等。一般标签都以加密形式附在密钥之后，仅当密钥解密后才同时恢复成明文。标签数据一般都很短。

（2）**密钥变形**。从一个基本密钥或衍生（derivation）密钥附加一些非秘密参数和一个非秘密函数导出不同的密钥，称所得的这种密钥为密钥变形或导出（derived）密钥。所用函数多采用单向函数。

（3）**密钥偏移（Key Offsetting）**。一个密钥加密密钥在每次使用后都要根据一个计数器所提供的增量进行修正，从而可以防止重放攻击。

（4）**密钥公证**。这是一种通过在密钥关系中，将参与者身份以显式方式加以说明来防止密钥代换的技术。通过这类身份对密钥进行认证，并修正密钥加密密钥，使得只有当身份正确时才能正确地恢复出受保护的密钥。这种方法可抗击模仿攻击，因而也可称为以身份密封的密钥。在所有密钥建立协议中都要防止密钥代换攻击。公证要求适当的控制信息，以保证精确恢复出加密的密钥，类似于隐式证实公钥系统，它可以对密钥提供隐式保护。

实现中可用一个可信赖服务器（公证或仲裁）或一个共享密钥的参与者，它由密钥加密密钥 K ，以及系统赋予发方和收方唯一性的 i 和 j 构成，以下式表示：

$$E_{K \oplus (i||j)}(K_S)$$

收方必须以共享秘密钥 K 和正确的 i, j 次序才可能恢复出密钥 K_S 。在有第三方参与时，它首先要对参与方的身份进行认证，然后向其提供只有这些参与者可以恢复的会话密钥，公证者可采用密钥偏移技术，见例 10-1。

例 10-1 采用偏移技术的密钥公证。设有字长为 64b 的分组码，密钥为 64b，密钥加密密钥 $K = K_L \parallel K_R$ 为 128b。 N 为 64b 计数器，发用户和收用户的识别符分别为 $i = i_L \parallel i_R$ 和 $j = j_L \parallel j_R$ 。公证人计算：

$$K_1 = E_{K_R \oplus i_L}(j_R) \oplus K_L \oplus N$$

$$K_2 = E_{K_L \oplus j_L}(i_R) \oplus K_R \oplus N$$

其中， N 为计数器存数。所得到的公证密钥(K_1, K_2)可作为 EDE 三重加密模式下所需的密钥加密密钥。称上述 $f_1(K_R, i, j) = E_{K_R \oplus i_L}(j_R)$ 和 $f_2(K_L, i, j) = E_{K_L \oplus j_L}(i_R)$ 为公证密封 (Notarized Seals)。若只需要 64b 的密钥时，可做一些修正，采用 $K_L = K_R = K$ ，计算上述 $f_1 = (K_R, i, j), f_2 = (K_L, i, j)$ ，将 f_1 的左边 32b 与 f_2 的右边 32b 链接成 64b 的 f ，而后计算 $f \oplus K \oplus N$ 作为公证密钥。

(5) 控制矢量。密钥公证可看做是一种建立认证的密码机构，控制矢量则是一种提供控制密钥使用的方法，是一种将密钥标签与密钥公证机构的思想进行组合的产物。对每个密钥 K_S 都赋予一个控制矢量 C ， C 是一个数但用于定义密钥的授权使用。每次对一个 K_S 加密之前先对 K 进行偏移，即 $E_{K \oplus C}(K_S)$ 。

密钥公证可以通过在控制矢量的数值中加入特定的身份说明来实现，也可以通过在 C 中限定主体的身份 ID_i 和密钥 K_S 的使用权限 $A(i, j)$ (可采用接入控制) 等技术来实现。

每次启用密钥时，都需输入控制矢量以实施对密钥的保护，系统检验控制矢量后才以它和密钥一起恢复出所要的密钥 K_S 。必须以正确的控制矢量 C 和正确的密钥加密密钥组成的值 $K \oplus C$ 才能恢复出 K_S ，这可以防止非授权接入密钥加密密钥 K 。

密钥的安全性取决于正确分离密钥的使用以及可信赖的系统。

当控制矢量 C 的数据长度超过密钥 K_S 的长度时，可以采用适当的杂凑函数先对 C 进行压缩。加密运算为 $E_{K \oplus h(C)}(K_S)$ 。

另外，如果附加上唯一性和时间性限制，如序号、时戳、一次性 Nonce 等，可以抗重放攻击。

有关密钥控制技术的研究可参阅相关文献[ISO8732 1987; ANSI X9.17 1985; Menezes 等 1997]。

10.10

多个管区的密钥管理

随着通信网间的互连，跨区、跨国的全球性通信网已经形成。本节介绍如何实现多个管区之间的密钥管理。

一个安全区 (Security Domain) 定义为在一个管理机构控制下的一个系统或子系统，系统中的每个实体都信赖该权威管理机构。管理机构以显式或隐式方式规定所管区内的安全策略，限定区内各实体的共享密钥或通行字，用以在实体与管理机构之间或两个实体之间建立一个安全信道，保证系统内的认证和保密通信。一个安全区可以是一个更大区中的一个层次。

令分属两个不同安全区 D_A 和 D_B 的实体为 A 和 B ，相应的可信赖机构分别为 T_A 和 T_B 。保证 A 与 B 实施可靠通信的要求，可以归结如下：

(1) 共享对称密钥在 A 和 B 之间建立共享密钥 K_{AB} ，双方都相信只有他们知道 K_{AB} （可信赖机构也可能知道）。

(2) 共享可信赖的公钥。对一个或更多个共用公钥的信赖可以作为安全区之间的信赖桥梁，彼此可以用来证实消息的真实性，或保证彼此之间传送消息的机密性。

这两种方式都可以维系 T_A 和 T_B 之间的信赖关系。有了这种关系就可以在 (A, T_A) 、 (T_A, T_B) 、 (T_B, B) 之间建立起安全通信信道，从而提供 (A, B) 之间的信赖关系，实现安全通信。

若 T_A 和 T_B 之间不存在信赖关系，可以通过他们共同信赖的第三机构 TC 作为中介，建立相互之间的信赖关系。这是一种信赖关系链（Chain of Trust）。下面介绍两种具体实现方式。

1. 可信赖对称密钥（Trusted Symmetric Keys）

可信赖的共享密钥可以通过各种认证的密钥建立技术获得。步骤如下：

- (1) A 向 T_A 提出与 B 共享密钥的请求。
- (2) T_A 和 T_B 间建立短期共享密钥 K_{AB} 。
- (3) T_A 和 T_B 分别向 A 和 B 安全可靠地分配 K_{AB} 。
- (4) A 用 K_{AB} 和 B 进行直接的保密通信。

2. 可信赖公钥（Trusted Public Key）

可信赖公钥可以在已有的信赖关系基础上通过标准的数据源认证，如数字签名或消息认证码等获得。步骤如下：

- (1) A 向 T_A 请求用户 B 的可信赖公开钥。
- (2) T_A 从 T_B 以可靠方式得到 B 的公开钥。
- (3) T_A 将其以可靠方式传送给 A 。
- (4) A 用此公钥和 B 进行直接的保密通信。

上面实现的是一种信赖的转递（Transfer of Trust）。这种转递还可以通过所谓的跨区证书（Cross Certificate）或 CA 证书（CA Certificate）实现。这种证书由一个证书机构（CA）创建，由另一个 CA 来证实其公钥。例如， T_B 为 B 建立一个证书 C_B ，其中有 B 的身份和公钥。 T_A 制作一个含有 T_B 身份和其公钥的跨区证书， A 有 T_A 的可信赖的签名证实密钥，则 A 就可以信赖 C_B 中的 B 的公钥（或 T_B 签署的任何其他证书的公钥）。因此，用户 A 就可以从 D_A 域的机构 T_A 获得由 T_B 签发的域 D_B 中实体的公钥。

各种可信赖模型都是通过对证书链中每个证书的证实所提供一种信赖关系。在跨区情况下，一旦 CA_X 对 CA_Y 的跨区公钥证书证实后，在无附加条件时， CA_X 就将这种对 CA_Y 的信赖传递给证书链可以到达的所有实体。为了对跨区证书这种信赖的扩展范围加以限制，CA 可以在签署证书中附加上约束条件，如限定证书链的长度或限定合法区的集，这些都可由证书策略做出规定。GSM，DECT，IS-54，Kerberos，PEM 和 SPX 系统都涉及多安全区的密钥管理问题，相关内容可参阅相关文献[Kent 1993; Tardo et al 1991；

Vedder 1991; Menezes et al 1997]。

10.11 密钥管理系统

一个系统中的密钥如果在所有时间上都是固定不变的, 则对其管理最为简单。但是任何实际系统的密钥都有一定的保密期, 需要及时更新, 这就使密钥管理变得复杂化了。例如, 密钥管理中心的证书机构要维护用户的公钥的注册、存储、分发、查询、吊销、更新等工作。这些工作又要依赖于认证、协议、加解密、签名、时戳、证书、可信赖的第三方公证、通信等技术的实现。密钥管理系统要负责密钥整个生存期 (Life Cycle) 的管理。

在网络通信环境中, 信使只适用于小型网络, 而分层法可用于中等规模的网络。随着网络规模的加大, 所需的密钥量越来越大, 手工式管理已不适用, 而要借助于计算机实施自动化管理, 由一个密钥分配中心负责管理分配密钥的工作。用这种电子分配密钥的方法, 成本较低、速度快, 而且较为安全, 适应通信网发展的需要。

图 10-17 是密钥管理系统框图, 它包括密钥生存期的所有各阶段的管理工作。

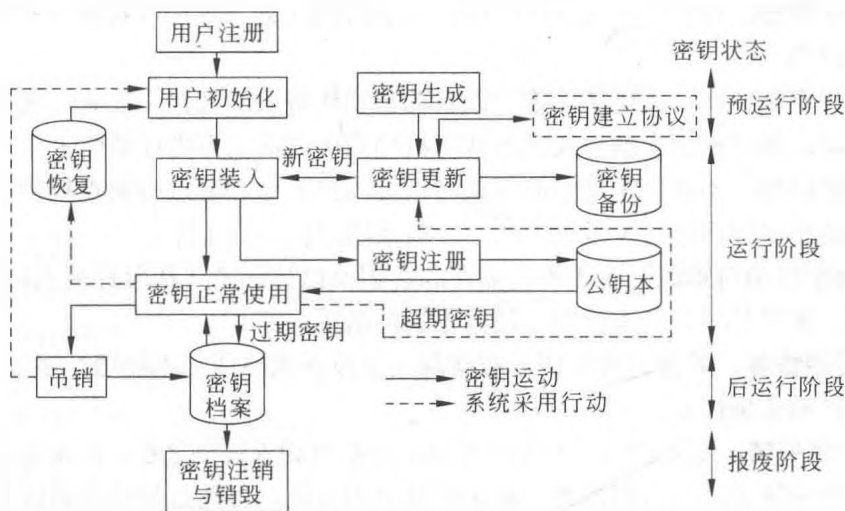


图 10-17 密钥管理系统框图

密钥的生存期有 4 个阶段, 即: ①预运行阶段, 此时密钥尚不能正常使用; ②运行阶段, 密钥可正常使用; ③后运行阶段, 密钥不再提供正常使用, 但为了特殊目的可以在脱机下接入; ④报废阶段, 将有关被吊销密钥从所有记录中删去, 这类密钥不可能再用。

密钥的生存期的 4 个阶段中共有下述 12 个工作步骤:

(1) **用户注册**。这是使一个实体成为安全区内的一个授权或合法成员的技术 (一次性)。注册过程包括请求, 以安全方式 (可以通过个人交换、挂号函件、可信赖信使等) 建立或交换初始密钥材料 (如共享通行字或 PIN 等)。

(2) **用户初始化**。一个实体要初始化其密码应用的工作, 如装入并初始化软、硬件,

装入和使用在注册时得到的密钥材料。

(3) 密钥生成。密钥的生成包括对密钥密码特性方面的测量，以保证生成密钥的随机性和不可预测性，以及生成算法或软件的密码上的安全性。用户可以自己生成所需的密钥，也可以从可信赖中心或密钥管理中心申请。

(4) 密钥输入。将密钥材料装入一个实体的硬件或软件中的方法很多，如手工送入通行字或 PIN、磁盘转递、只读存储器件、IC 卡或其他手持工具（如密钥枪）等。初始密钥材料可用来建立安全的联机会话，通过这类会话可以建立会话（工作）密钥。在以后的更新过程中，仍然可以用这种方式，以新的密钥材料代替旧的密钥材料。当然，最理想的办法是通过安全联机更新技术实现。

(5) 密钥注册。和密钥输入有关联的是密钥材料，可以由注册机构正式地记录，并注明相应实体的唯一性标记，如姓名等。这对于实体的公钥尤为重要，常由证书机构制定公钥证书来实现正式注册，并通过公钥本或数据库等在有关范围内公布，以供查询和检索。

(6) 正常使用。利用密钥进行正常的密码操作（在一定控制条件下使用密钥），如加/解密、签名等。双钥体制的两个密钥可能有不同的使用期。例如，公钥可能已过期不能再使用，但密钥仍可继续用于解密。

(7) 密钥备份。以安全方式存储密钥，用于密钥恢复。备份可看做是密钥在运行阶段内的短期行为。

(8) 密钥更新。在密钥过期之前，以新的密钥代替旧的密钥。其中，包括密钥的生成、密钥推导，执行密钥交换协议或与证书机构的可信第三方进行通信等。

(9) 密钥档案。不再正常使用的密钥可以存入档案中并通过检索查找使用，用于解决争执。这是密钥的后运行阶段的工作。一般采用脱机方式工作。

(10) 密钥注销与销毁。对于不再需要的密钥或已被注销（从所有正式记录中除名）用户的密钥，要将其所有副本销毁，使其不能再出现。

(11) 密钥恢复。若密钥丧失但未被泄漏（如设备故障或记不清通行字），就可以用安全方式从密钥备份恢复。

(12) 密钥吊销。如果密钥丢失或因其他原因在密钥未过期之前，需要将其从正常运行使用的集合中除去，即密钥吊销。对于证书中的公钥，可通过吊销公钥证书实现对公钥的吊销。

上述 12 个步骤，除密钥恢复和吊销外均属正常工作步骤。单钥体制的密钥管理要比双钥体制简单些，通常没有注册、备份、吊销或存档等。但一个大系统的密钥管理仍然是一项十分复杂的任务。

整个密钥管理系统也需要一个初始化过程，以便提供一个初始化安全信道有选择地支持其后的（长期和短期）工作密钥的自动化建立。初始化是一种非密码的工作（一次性），将密钥材料由管理者亲自（由可信赖信使或通过其他可信赖信道）装入系统。初始化阶段密钥的装入对整个密钥管理系统的安全至关重要，为此常常需要采用双重或分拆控制，由两个或更多可信赖者独立地实施。

有关密钥管理系统的研究可参阅相关文献[ISO/IEC11770 1996a; ANSI X9.57 1995; ISO10202-7 1994; Menezes 等 1997]。

习 题

一、填空题

1. 网络加密方式有 4 种, 它们分别是_____、_____、_____和_____。
2. 在通信网的数据加密中, 密钥可分为_____、_____、_____和_____。
3. 密钥分配的基本方法有_____、_____和_____等。
4. 在网络中, 可信第三方 TTP 的角色可以由_____、_____、_____和_____等来承担 (请任意举出 4 个例子)。
5. 按照协议的功能分类, 密码协议可以分为_____、_____和_____。
6. Diffie-Hellman 密钥交换协议不能抵抗_____攻击。
7. Kerberos 提供_____。
 - A. 加密
 - B. SSO
 - C. 远程登录
 - D. 本地登录
8. 在 Kerberos 中, 允许用户访问不同应用程序或服务器的服务器称为_____。
 - A. AS
 - B. TGT
 - C. TGS
 - D. 文件服务器
9. 在 Kerberos 中, _____与系统中的每个用户共享唯一一个口令。
 - A. AS
 - B. TGT
 - C. TGS
 - D. 文件服务器

二、思考题

1. 网络加密有哪几种方式? 请比较它们的优缺点。
2. 请分析比较硬件加密和软件加密的优缺点。
3. 密钥管理包含哪些内容? 密钥管理需要借助于哪些密码技术来完成?
4. 密钥有哪些种类? 它们各自的用途是什么? 请简述它们之间的关系。
5. 一个好的密钥应该具备哪些特性?
6. 在实际系统中, 如何产生和选择好的密钥?
7. 密钥分配的基本模式有哪些?
8. 密钥分配协议有哪些种类? 在密钥交换时为什么需要进行身份认证?
9. 在实际工作中, 有哪些密钥分配的方法? 有哪些自动分发密钥的方法?
10. 什么是隐式证实公钥系统? 它可以分为哪几类?
11. 在密码系统中, 密钥是如何进行保护、存储和备份的?
12. 在实际系统中, 如何对密钥进行控制? 单钥体制中的密钥控制技术有哪些?
13. 密钥如何撤销和销毁?